

Goldilocks Audit Summary

Prepared by Cyfrin

Version 1.1

Lead Auditors

Hans

April 14, 2024

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 3

7 Risk Classification 4

8 Protocol Summary 4

9 Attestation 4

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Goldilocks on Goldilocks. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 1.1 dated April 14, 2024, was delivered to Goldilocks, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Goldilocks or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 16 days, the Cyfrin team conducted an audit on the Goldilocks code provided by Goldilocks. The findings consist of 6 High, 6 Medium & 7 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	Goldilocks
Repository	goldilocks-core
Commit	0822d92fe18a...
Audit Timeline	March 18th - April 8th, 2024
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	0	0
High Risk	6	6	0
Medium Risk	6	5	1
Low Risk	7	5	2
Informational	2	–	–
Gas Optimizations	5	–	–
Total	26	–	–

The report records no status for its Informational findings and Gas Optimizations.

6 Audit Scope

The following Solidity files were included in the scope of the audit:

```
Goldilend.sol
Goldiswap.sol
Goldivault.sol
OwnershipToken.sol
YieldToken.sol
Goldigovernor.sol
Timelock.sol
Govlocks.sol
Goldilocked.sol
```

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

Goldilocks is a DAO focused on creating specialized DeFi infrastructure for Berachain.

Key components:

- **Goldiswap:** a custom-designed AMM that users can buy and sell LOCKS with. It includes two primary liquidity pools, the Floor Supporting Liquidity Pool (FSL) and the Price Supporting Liquidity Pool (PSL), which consist of HONEY, Berachain's native stablecoin.
- **Goldilend:** an NFT lending platform designed exclusively for Bong Bear NFTs and their rebases, enabling holders to obtain loans against their NFTs without the risk of price-based liquidations. Users can lock partner NFTs to decrease the interest rate paid on a loan or boost PORRIDGE yield for GiBGT stakers.
- **Goldivault:** vaults for yield splitting, enabling users to trade and speculate on the future earnings generated by yield-bearing positions across Berachain's native and blue-chip DeFi protocols.

Tokens:

- **LOCKS:** governance token for Goldilocks DAO
- **govLOCKS:** governance wrapper for LOCKS
- **PRG:** Porridge token
- **GiBGT:** ownership token of Goldilend
- **HONEY:** external token, stablecoin on Berachain
- **iBGT:** external token, Infrared governance token

9 Attestation

Cyfrin attests that it performed a security review of the Goldilocks code provided by Goldilocks.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2024-04-14-cyfrin-goldilocks-v1.1.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Goldilocks has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=44d5c70bc055deddb439ae85cb402b93c5508ee4d73e9a94f8cfb5405c20e304
F=2024-04-14-cyfrin-goldilocks-v1.1-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.